this book.

- The use of and strength of multi-factor authentication (MFA) can prevent some attacks. Just resetting credentials wouldn't have been sufficient with good MFA in place. We'll discuss MFA in detail later in this chapter.
- Adopting a zero-trust security model that assumes breach and challenges people to reassert their credentials when moving from system to system is a critical practice for modern IT systems. Contingent authorization can take this a step further, requiring special permissions for high-consequence actions.
- Humans remain the weakest link. No matter how secure a system is, if an attacker can manipulate people into doing their bidding, authentication fails to stop them. Removing places where humans can override the system can strengthen your security.

This incident underscores why authentication isn't just about logging in—it's about ensuring the integrity of the relationship that was established when the account was created.

3.1 Terminology

In this chapter, and throughout this book, I'm going to use several terms repeatedly, so it's a good idea to define them clearly before we begin:

- **Account**—a container for information about an entity. The account holds attributes, credentials, roles, and other context about the entity.
- **Identifier**—a string that uniquely identifies a particular account in the namespace for a given system.
- **Principal**—the entity (such as a person or organization) making a request.
- **Subject**—the entity being referred to in an account, policy, or decision.

You may notice that I didn't include the word *identity* in the list. Identity can mean different things depending on context. In most cases, I find that there is a more precise term, such as *account*, *identifier,* or *principal*. Using more specific language helps reduce confusion and makes the discussion clearer.